EWB COURSES

AI-POWERED CYBERSECURITY

Assessment 01
Security Foundations

Individual Assessment Report | Tasks A–D

Student name	**SANTHOSH KUMAR R**
Batch / Group	**Batch 1**
Assessment issued	**18 October 2026**
Submission format	**PDF report**

Scope: This report analyses only the fictional scenarios and synthetic log entries supplied in Assessment01. No live systems, real accounts, passwords, OTPs or personal data were accessed or tested.

Task A | Secure a Student Account

A1–A2. Risks, Assets, CIA impact, controls and limitations

CIA means confidentiality (preventing unauthorized disclosure), integrity (protecting information from unauthorized change) and availability (keeping information accessible when needed).

Risk	Asset	CIA impact	Practical control	Limitation
1. Reusing a short password	Email and learning-portal accounts; messages and coursework	Confidentiality: compromise of one service may expose the other. Integrity: an intruder could change account details or coursework.	Use a long, unique password for each account; use a reputable password manager and enable MFA where offered.	A password manager must itself be protected. Unique passwords do not stop phishing or malware.
2. Approving unexpected sign-in prompts	Account credentials, email and portal content	Confidentiality: an unauthorized login may expose private data. Integrity: the intruder may alter or delete work.	Deny prompts Mira did not initiate; report repeated prompts through the college's official support channel and review account activity.	This relies on Mira recognizing the prompt. A legitimate prompt can still be confusing, so training and clear reporting routes matter.
3. Delaying device updates	Laptop, operating system, browser and stored data	Confidentiality and integrity: attackers may exploit known vulnerabilities. Availability: malware or system damage may interrupt use.	Enable automatic updates and restart promptly to install security fixes.	Updates cannot remove every risk and may occasionally cause compatibility problems; backups and endpoint protection remain

				useful.
4. Keeping the only project copy on one laptop	Assignments, project files and study materials	Availability: theft, loss, disk failure or ransomware could make the only copy unavailable. Integrity: corrupted files may go unnoticed.	Keep a versioned backup in secure cloud storage or on an encrypted external drive, and test that files can be restored.	A backup that is not updated may be incomplete. A connected backup can also be affected by ransomware; keep a separate or protected copy.
5. Letting a friend use Mira's signed-in session	Email, learning portal, personal files and browser sessions	Confidentiality: the friend can view private information. Integrity: files, settings or submissions could be changed or deleted.	Sign out or lock Mira's session and create a separate standard (non-administrator) account for the friend.	Separate accounts reduce casual access but do not prevent all physical access, malicious software or deliberate misuse.

Prioritized first three actions

1. **Secure both accounts immediately.** Replace the reused password with unique passwords and enable MFA. This comes first because a single exposed password could provide a route into both important accounts. If an unexpected prompt has been approved, Mira should also use a trusted device and official account-recovery process to secure the account.

2. **Stop approving unrequested prompts.** Deny them and report repeated requests. This is urgent because an approval may complete an attacker's sign-in attempt. Account security should not depend on guessing whether a prompt is genuine.

3. **Separate laptop use.** Lock Mira's session and create a separate standard account for her friend. This prevents ordinary shared use from inheriting Mira's signed-in access. Updates and backups should follow promptly.

Authentication versus authorization

Authentication verifies who is signing in. For example, Mira enters her account identifier and password and completes an MFA check to prove that she is the account holder. **Authorization** decides what that verified account is allowed to do. After login, Mira may be allowed to view course materials and upload her own assignment, while being denied permission to change another student's submission or administer the portal. Authentication answers “Who are you?”; authorization answers “What may you do?”

Task B | Analyze a Suspicious Message

B1. Warning signs in the supplied message

Evidence phrase	Why it needs scrutiny
"From: awards@campus-awards.example" and "Reply-To: help@personal-awards.example"	The reply address differs from the displayed sender domain. This mismatch should be checked independently; it is a warning sign, not proof by itself.
"FINAL WARNING" and "expires in 20 minutes"	Artificial urgency pressures the recipient to act before checking the claim.
"enter your college password and OTP"	A message asking for both a password and one-time code creates a serious credential-theft risk. Do not enter or disclose them through a link in an unsolicited message.
"Do not contact the college office because their system is	It discourages independent verification and tries to isolate the recipient from a trusted source.

unavailable"	
"Reply with a photo of your identity card"	It requests sensitive identity information through an unverified channel, creating privacy and identity-misuse risks.

The college's normal domain is stated to be campus. example, while the sender and reply-to use other domains. The supplied URL also uses a related-looking but different domain, campus-awards.example. These are reasons to investigate, not enough evidence to identify the sender or prove what a website would do.

B2. Safe verification process

1. Do not click the message link, reply, provide credentials/OTP or send an identity-card image. Preserve the message, including its sender and reply-to details.
2. Open the learning portal using a bookmark or an address independently obtained from college materials, or contact the college office using a phone number/email from an official directory already known to be genuine.
3. Ask the scholarship or student-support team whether the award and deadline are real. Report the message using the college's official phishing-reporting route.
4. Follow only instructions confirmed through that independent channel. HTTPS encrypts a connection between a browser and a site; it does not establish that the site belongs to the college or that its request is legitimate. A familiar display name can be chosen by a sender and is not reliable proof of identity.

B3. If a student already entered a password and OTP

1. **Contain immediately:** Stop interacting with the message. From a trusted device, use the colleges independently verified portal or official support route to change the compromised password. Change it anywhere else it was reused. Do not share the old or new password or OTP with anyone. Ask IT to revoke active sessions/tokens and reset MFA if compromise is suspected.
2. **Report:** Contact the college IT/security team and scholarship office through independently verified contact details. Provide the message, approximate time, account affected and actions taken, but never include the password or OTP. Preserve the original message and relevant alert details.
3. **Follow up:** Review recent sign-ins, recovery email/phone, MFA methods, forwarding rules and account changes. Check for unauthorized messages or file changes. Monitor for further suspicious activity and follow IT's recovery advice.

B4. What cannot be established

The message alone cannot establish who actually sent it, whether the sender account was spoofed or compromised, or whether the linked domain is controlled by an attacker. Additional evidence could include full email headers (including authentication results such as SPF, DKIM and DMARC), confirmation from the college through its official channel, and a security team's controlled review of domain and mail infrastructure. The sample addresses are fictional and must not be visited.

Task C | Triage a Sign-in Alert

C1. Four-point timeline: observed events and interpretation

Time (IST)	Observed evidence	Interpretation (not proven fact)
09:00–09:01	Password success and MFA approved from usual classroom egress IP 192.0.2.10.	A successful sign-in occurred. This is consistent with normal access, but the log alone does not prove who operated the account.
10:14–10:16	Two password failures, followed by password success from 198.51.100.23.	There may have been repeated attempts before a successful password entry. The log does not reveal whether the password was guessed, previously known or entered by the student.

10:17–10:18	MFA was first denied and then approved from the same source IP. Student07 says they approved a prompt at about 10:18 to stop repeated requests.	The approval is consistent with the student's statement. It may have allowed a sign-in the student did not intend to authorise.
10:20	A session was created from 198.51.100.23. Student07 says they did not sign in after 09:05.	A session followed the MFA approval. This conflicts with the student's stated intention and warrants urgent investigation; the IP is not an identity.

C2. Likely explanation, alternative and distinguishing checks

Likely explanation: Someone other than the student had or obtained the password, made repeated attempts, and the student unintentionally approved the unexpected MFA prompt. The session was then created after that approval. This is a plausible account-compromise scenario, not a proven attribution.

Alternative explanation: The student initiated or indirectly triggered a legitimate sign-in from a different network/device (for example, a VPN, mobile network or changed egress route), and the repeated prompts were part of that attempt. Their recollection of the timing may be incomplete.

Two useful checks: (1) Correlate identity-provider records with device/session identifiers, browser/device details, MFA method and token/session issuance/revocation events. (2) Ask the student, through a trusted channel, to confirm their devices, network/VPN use and exact prompt details; compare with endpoint and network logs if authorized. A source IP alone cannot identify a person.

C3. Three prioritized actions for the authorized IT team

1. **Protect the account:** Contact the student through a verified channel, temporarily block or restrict the account if policy permits, revoke active sessions/refresh tokens, reset credentials and review or re-register MFA. Require a fresh sign-in from a trusted device. Do not ask for the password or OTP.
2. **Preserve evidence:** Export the relevant authentication, MFA, session, endpoint and network logs with timestamps and time zone; preserve original records, record who collected them and when, and restrict access to the evidence. Avoid deleting or altering logs.
3. **Investigate and monitor:** Review account changes, recovery methods, mailbox forwarding rules, file access and activity after 10:20. Check for similar attempts against other accounts and monitor for renewed suspicious activity. Escalate under the college incident-response process.

C4. Incident summary (60–100 words)

The synthetic logs show a successful sign-in at 09:00–09:01 from the usual classroom egress, followed at 10:14–10:16 by two password failures and a password success from a different documentation IP. MFA was denied and then approved at 10:18, and a session was created at 10:20. Student07 says they did not initiate a sign-in and approved the prompt to stop repeated requests. Account compromise is plausible but not proven; the IP does not identify a person. Priority: secure the account, revoke sessions and preserve logs for authorized review.

Task D | Review an AI Security Answer

D1. Five unsafe or unsupported claims/actions and corrections

AI output claim/action	Correction and reason
"The email is safe because it uses HTTPS."	Incorrect. HTTPS protects data in transit between browser and website, but does not prove the domain or message is genuine. Verify through an independently obtained official college contact or portal.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported. The logs show events associated with a source IP, not the identity of a person or how the password was obtained. Consider shared networks, VPNs and other explanations.
"MFA prevents every account compromise."	False. MFA reduces risk but can be defeated or misused through approval fatigue, phishing, stolen sessions or social engineering. Mira/student07's approval of an unexpected prompt illustrates the limitation.

"Delete the suspicious logs."	Unsafe. Logs are evidence needed to establish the sequence, scope and impact of an incident. Preserve them with access controls and collection details; do not delete or modify them.
"Send the student's password to support so they can test it."	Unsafe. Support staff should never need the student's password or OTP. The student should change compromised credentials through the official process; IT can investigate using logs and approved administrative tools.

D2. Safer prompt for an AI tool

"Analyze only the fictional email evidence and synthetic sign-in log included below. Do not access websites, systems or external accounts. Separate directly observed facts from interpretations and assumptions. Identify plausible explanations and alternative explanations, and state what cannot be concluded from the evidence. Recommend safe, proportionate actions for the account owner and authorized IT team. Do not request, reveal, infer or reproduce passwords, OTPs, identity documents or other secrets. Do not identify or attribute activity to a person based only on an IP address. Explain uncertainty and cite trustworthy security guidance where relevant. If evidence is insufficient, say what additional authorized evidence would help."

D3. Corrected security advice (100–150 words)

Treat the scholarship message as unverified. Do not open its link, reply, enter a password or OTP, or send an identity-card image. Check the scholarship through the college portal reached from a trusted bookmark or contact the college using details from an official directory. HTTPS and a familiar sender name do not prove legitimacy. In the sign-in log, the different source IP, password failures, MFA denial and later approval followed by session creation are suspicious, but they do not identify a person or prove how the password was obtained. The student should contact IT through a verified channel, change the password from a trusted device, revoke active sessions and review MFA and account activity. IT should preserve logs and investigate before drawing conclusions.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: ChatGPT (OpenAI) was used to help organize the report, explain foundational security concepts and draft/review wording against the assessment questions. The scenarios and log entries were treated as fictional evidence. The student should personally review, understand and edit the final wording before submission.

Evidence note 1 – CISA: CISA's Secure Our World guidance covers strong passwords, password managers, multifactor authentication, software updates and phishing awareness. These principles support the account controls and suspicious-message response in Tasks A and B. Reference: https://www.cisa.gov/secure-our-world

Evidence note 2 – NIST: NIST AI 600-1, the Generative Artificial Intelligence Profile, discusses risks including confabulation (plausible but incorrect AI-generated content) and the need to evaluate and verify outputs. This supports checking the AI claims against the supplied evidence and authoritative security guidance rather than accepting them automatically. Reference: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

Reference list

1. Cybersecurity and Infrastructure Security Agency (CISA), "Secure Our World", https://www.cisa.gov/secure-our-world (accessed for foundational guidance; verify the current page before submission).

2. National Institute of Standards and Technology (NIST), *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST AI 600-1, https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf.

3. EWB Courses, *AI-Powered Cybersecurity – Assessment 01: Security Foundations*, issued 18 October 2026, pages 1–4 (scenario and synthetic evidence supplied in the assessment brief).

**********End of report**********